Feature SCA-2237 Created by Sergio Santos on Feb 28, 2025

SCA JFrog Artifactory plugin for artifact compliance validation in cloud instances and on-prem k8s deployments using workers

Description

Description & Value:

We want to create a JFrog Artifactory plugin that validates the security and legal compliance of artifacts at two critical points: during upload to the repository and during download for builds. It evaluates artifacts against user-defined policies, ensuring adherence to security standards, license requirements, and organizational guidelines. Non-compliant artifacts are blocked, with detailed feedback provided to developers to address violations effectively.

By enforcing compliance at both upload and download stages, the plugin enhances security, prevents legal risks, and ensures consistent governance across the software supply chain. It reduces the likelihood of vulnerabilities or licensing conflicts while promoting developer awareness and maintaining seamless workflows.

Background:

The existing plugin documentation and capacities can be found in the attached document.

PRD Requirements:

Core functionality

- A new plugin for on-prem and Cloud based Jfrog Artifactory must be available to scan artifacts.
- The plugin must be made available for CxOne ST and MT customers only.
- The plugin must validate the license before operating, making sure it's a valid CxOne customer.

Release	SCA-R-80 Q1 - 2025
Type	Roadmap (customer)
Status	Detailed Requirements Ready
Organization	Bank of Nova Scotia, Elevance Health, Guidewire Software, Inc., [Hidden organizatic
Progress	
Integrations	No integrations
Assigned to	Sergio Santos
Initiative	SCA-S-25 Support Red customers, POVs and Strategic
Epic	SCA-E-518 Support red customer and Commit
Product Area	No Product Area selected
UI/UX required ?	Yes (UI/UX Required)

- The plugin will validate the compliance of SCA packages and container images.
- The plugin must support the following package managers for SCA packages: Bower, CocoaPods, Composer, Go, Gradle, Ivy, Maven, Npm, Nuget, Pypi, Sbt
- The plugin must support the following images types: OCI, Docker and Singularity

Compliance thresholds:

- Each artifact must have a compliance status, that can be compliant or not compliant.
- An artifact will be marked as not compliant if it violates one of the defined thresholds.
- The thresholds for an artifact that can be set by the user are:
  - Number of Critical vulnerabilities of the artifact (SCA and Containers)
  - Number of High vulnerabilities of the artifact (SCA and Containers)
  - Number of of Medium vulnerabilities of the artifact (SCA and Containers)
  - Number of Low vulnerabilities of the artifact (SCA and Containers)
  - If the artifact was identified as Malicious (SCA and Containers)
  - The licenses associated to the artifact (SCA only)

Plugin configuration file

- A configuration file must be available as part of the plugin installation name "cxsupplychainsecurity-plugin.properties" to allow the configuration of the compliance threshold.
- The following configuration lines must be available in the "cxsupplychainsecurity-plugin.properties" file

Scope	Name	Values	Default	Purpose
SCA	cxsca.security.risk.critical.threshold	none, 0-∞	none	Setting to configure how many Critical risk vulnerabilities are accepted in the artifact

External Release Notes required?	Yes (External RN required)
Internal Release Notes required?	No (Internal RN NOT required)
Documentation required ?	Yes (Documentation required)
AppSec Research required ?	NO (AppSec Research not required)
External_RoadMap (Feature)	No External_RoadMap (Feature) selected
Commitment	Focus Area
Committed For Customer...	Bank of Nova Scotia
Original Commitment Delivery Date	
Commitment Delivery Date	04/30/2025
Commitment delivered	No Commitment delivered selected
Commitment Delivered On Time?	No Commitment Delivered On Time? selected
Feature Priority	

				before violating the threshold. "none" means that the property is not evaluated.
SCA	cxsca.security.risk.high.threshold	none, 0-∞	none	Setting to configure how many High risk vulnerabilities are accepted in the artifact before violating the threshold. "none" means that the property is not evaluated.
SCA	cxsca.security.risk.medium.threshold	none, 0-∞	none	Setting to configure how many Medium risk vulnerabilities are accepted in the artifact before violating

Date range Start on — Due on

Initial estimate

Detailed estimate

Actual effort Log time

Tags BNS

Risk / Comment

HLE←

Team Text←

Lead Architect Text←

Feature Owner ←

Assignee R&D Text←

Released Version←

*R&D Committed←

Planned For Quarter

Sprint←

Feature Flag Name

				the threshold. "none" means that the property is not evaluated.
SCA	cxsca.security.risk.low.threshold	none, 0-∞	none	Setting to configure how many Low risk vulnerabilities are accepted in the artifact before violating the threshold. "none" means that the property is not evaluated.
SCA	cxsca.security.allowmalicious	yes/no	no	Setting to configure if Malicious Packages are allowed or not. If the setting is set to false "no", malicious artifacts will

Priority (Category) No Priority (Category) selected

Planned Version

*Planned Version No *Planned Version selected

*Version Cut Date

*Canary Deploy Date

*MT deploy Date

*ST Deploy Date

Product Area - (Group) No Product Area - (Group) selected

Feature_History_ENR

Account_Name_ENR

Planned_Version_ENR

count of account

Refresh

count	= 0
Blank for import CSV	

Last updated Feb 28, 2025 2:37 PM

Account_Name_Test

Organization_Tags

Elevance Health | Bank of Nova Scotia | Inc. | [Hidden organization] | Guidewire Software

				violate the threshold.
SCA	cxsca.security.allowedlicenses	[licenses IDs]	MIT,Apache 2.0,BSD 3,ISC,Zlib	Setting to configure the list of the allowed licenses in the organization. If an artifact license is not listed on this setting, it will violate the threshold.
SCA	cxsca.security.blockbydefault	yes/no	no	Setting to configure if artifacts that are found as not compliant should be blocked on upload or download.
Containers	cxcontainers.security.risk.critical.threshold	none, 0-∞	none	Setting to configure how many Critical risk vulnerabilities are accepted in the artifact

				before violating the threshold. "none" means that the property is not evaluated.
Containers	cxcontainers.security.risk.high.threshold	none, 0-∞	none	Setting to configure how many High risk vulnerabilities are accepted in the artifact before violating the threshold. "none" means that the property is not evaluated.
Containers	cxcontainers.security.risk.medium.threshold	none, 0-∞	none	Setting to configure how many Medium risk vulnerabilities are accepted in the artifact before violating

				the threshold. "none" means that the property is not evaluated.
Containers	cxcontainers.security.risk.low.threshold	none, 0-∞	none	Setting to configure how many Low risk vulnerabilities are accepted in the artifact before violating the threshold. "none" means that the property is not evaluated.
Containers	cxcontainers.security.allowmalicious	yes/no	no	Setting to configure if Malicious Packages are allowed or not. If the setting is set to false "no", malicious artifacts will

				violate the threshold.
Containers	cxcontainers.security.blockbydefault	yes/no	no	Setting to configure if artifacts that are found as not compliant should be blocked on upload or download.

Artifact UI properties

- The artifact must be enhanced with the following JFrog Artifact Properties if they are found as an SCA artifact:

Property name	Type	Purpose
CxSCA.TotalVulnerabilities	Output - Number (0 to ∞)	The total of vulnerabilities identified for the artifact
CxSCA.Vulnerabilities.Critical	Output - Number (0 to ∞)	The total of Critical vulnerabilities identified for the artifact
CxSCA.Vulnerabilities.High	Output - Number (0 to ∞)	The total of High vulnerabilities identified for the artifact
CxSCA.Vulnerabilities.Medium	Output - Number (0 to ∞)	The total of Medium vulnerabilities identified for the artifact

CxSCA.Vulnerabilities.Low	Output - Number (0 to ∞)	The total of Low vulnerabilities identified for the artifact
CxSCA.IsMalicious	Output - yes/no	If the artifact was found to be malicious
CxSCA.Licenses	Output - [string]	The licenses identified by the package
Cx.LastScanned	Output - Date	The date of the last scan of the artifact
Cx.IsCompliant	Output - yes/no	The compliance status of the artifact
Cx.ForceAllow	Input - yes/no	Force the artifact to be downloaded, ignoring the compliance value
Cx.IsBlocked	Output - yes/no	If the artifact is currently blocked and not available in the repository

- The artifact must be enhanced with the following JFrog Artifact Properties if they are found as an Container image:

Property name	**Type**	**Purpose**
CxContainer.TotalVulnerabilities	Output - Number (0 to ∞)	The total of vulnerabilities identified for the artifact
CxContainer.Vulnerabilities.Critical	Output - Number (0 to ∞)	The total of Critical vulnerabilities

		identified for the artifact
CxContainer.Vulnerabilities.High	Output - Number (0 to ∞)	The total of High vulnerabilities identified for the artifact
CxContainer.Vulnerabilities.Medium	Output - Number (0 to ∞)	The total of Medium vulnerabilities identified for the artifact
CxContainer.Vulnerabilities.Low	Output - Number (0 to ∞)	The total of Low vulnerabilities identified for the artifact
CxContainers.IsMalicious	Output - yes/no	If the artifact was found to have malicious packages
Cx.LastScanned	Output - Date	The date of the last scan of the artifact
Cx.IsCompliant	Output - yes/no	The compliance status of the artifact
Cx.ForceAllow	Input - yes/no	Force the artifact to be downloaded, ignoring the compliance value
Cx.IsBlocked	Output - yes/no	If the artifact is currently blocked and not available in the repository

Artifact scanning events and actions

1. When it is first installed, the plugin must automatically scan all artifacts and check their compliance status:
    a. For each artifact, the property "Cx.IsCompliant" will be set accordingly with the compliance validation.
2. The plugin must automatically scan and check the artifact compliance status when it is added to the JFrog repository:
    a. If the artifact is compliant, the artifact will be added to the repository together with the artifact properties, including the ones added set by Cx.
    b. If the artifact is not compliant and plugin setting "cxX.security.blockbydefault" is set to "no":
        i. The "Cx.IsCompliant" property is set to "no".
        ii. The "Cx.IsBlocked" property is set to "no".
        iii. A message must be presented to the user: *"Artifact Not Compliant: This artifact does not comply with the following compliance conditions: Condition_1, Condition_2,..."*
    c. If the artifact is not compliant and plugin setting "cxX.security.blockbydefault" is set to "yes":
        i. The artifact binary is not added to the repository.
        ii. The properties for such artifact, the ones from the artifact metadata and the ones added by Checkmarx, will still be added.
        iii. The property "Cx.IsCompliant" property is set to "no".
        iv. The property "Cx.IsBlocked" property is set to "yes".
        v. A message must be presented to the user: *"Artifact Blocked: This artifact does not comply with the following compliance conditions: Condition_1, Condition_2,..."*
3. The plugin must automatically scan and check the artifact compliance status when it is downloaded from the repository as part of the build process.
    a. If the artifact is not compliant and plugin setting "cxX.security.blockbydefault" is set to "no":
        i. The artifact is allowed to be downloaded from the repository.
        ii. The "Cx.IsCompliant" property is set to "no".
        iii. The "Cx.IsBlocked" property is set to "no".
        iv. A message must be presented to the user: *"Artifact Not Compliant: This artifact does not comply with the following compliance conditions: Condition_1, Condition_2,..."*

    b. If the artifact is not compliant and plugin setting "cxX.security.blockbydefault" is set to "yes":
        i. The artifact is blocked from being downloaded from the repository.
        ii. The property "Cx.IsCompliant" property is set to "no".
        iii. The property "Cx.IsBlocked" property is set to "yes".
        iv. A message must be presented to the user: *"Artifact Blocked: This artifact does not comply with the following compliance conditions: Condition_1, Condition_2,..."*
4. The plugin must allow the user to manually trigger a scan of all artifacts in the repository in order to revaluate the overall compliance status of the artifacts available.
    a. If the artifact is compliant:
        i. The "Cx.IsCompliant" property is set to "yes".
        ii. The "Cx.IsBlocked" property is set to "no".
    b. If the artifact is not compliant and plugin setting "cxX.security.blockbydefault" is set to "no":
        i. The "Cx.IsCompliant" property is set to "no".
        ii. The "Cx.IsBlocked" property is set to "no".
5. The user must be able to override a blocked component so it can be used if not compliant.
    a. The user can change the "Cx.ForceAllow" property between "yes" and "no".
    b. If the setting is "no, then the component will be blocked if not compliant.
    c. If the setting is "yes", then the component will be allowed to be added or downloaded.
6. A rate limit for artifacts validation should be set to balance workload on CxOne instances.

Out-of-Scope

- None

Open Questions:

- None

Customer feedback:

BNS:

- ** Is your Artifactory deployment managed via Kubernetes (K8s)? No, Artifactory deployment is not managed by Kubernetes.
  - Which version of Artifactory are you currently using? Enterprise Plus 7.63.22
  - Are you subscribed to the "Enterprise X" or "Enterprise +" edition? Enterprise +
  - Are you using a single Artifactory instance, or do you operate multiple instances? Our Artifactory is hosted on-prem, with primary and DR site. Single instance of Artifactory, running on 2 servers.

Elevance Health:

- No major gaps identified
- They aim for SCA + Containers
- Multiple on-prem JFrog Artifactory instances
- 11.000.000+ artifacts
- Package managers: NPM, Python

Guidewire:

- They use JFrog Cloud
- "millions" of artifacts



Checkmarx SCA Plugin...

Requirements

There are no requirements for this feature yet.

Related

Linked records 4

Belongs to initiative SCA-S-25 Support Red customers, POVs and Strategic clients On track

Belongs to epic SCA-E-518 Support red customer and Commitments Q1_2025 Detailed Requirements Ready

Relates to AST-4304 Jfrog | Support Cloud Artifactory Deployed [In Production]

Relates to AST-4847 Jfrog | Support and Improvements Open

Research

Concepts



Spark creativity

Add notes and whiteboards to kick off the creative process

Ideas

Gather feedback

Link to existing ideas submitted by customers and the team

Perspectives